

Web Exploitation Workshop

15-11-2025

10:30AM

ISD

I. Introduction

This report presents all the **essential concepts** covered during the Web Exploitation Workshop, designed to introduce students and members to the **fundamentals** of web security, network architecture, and practical penetration testing techniques. The report is divided into two main parts:

- **Theoretical Foundations:** Core principles of networking, web vulnerabilities, security mechanisms, and exploitation methods.
- **Practical Demonstration:** A hands-on example illustrating how these concepts are applied in real-world testing scenarios. (Page: 13)

II. Theoretical Foundations:

1. CTF knowledge & Certification

CTF (Catch the flag) : cybersecurity is a competitive event where participants solve **technical challenges** to find hidden pieces of data called “*flags*.” Each flag you capture gives you points. Decrypting somethings/ sql injection/ brotforst

Certifications :

Certification / Program	Cost	Description & Focus	Official Link
Linux Professional Institute Certificate – LPIC-1	Exam paid, study materials free	Industry-recognized Linux certification (system administration, shell, filesystems, networking). Great for beginners in cybersecurity.	https://www.lpi.org/our-certifications/lpic-1

Google Cybersecurity Professional Certificate	Free to audit, certificate paid unless using financial aid	Intro to cybersecurity, Linux basics, Python, SIEM tools, incident detection. Very beginner-friendly.	https://www.coursera.org/professional-certificates/google-cybersecurity
IBM SkillsBuild – Cybersecurity Analyst Certificate	100% free	Teaches SOC basics, threat detection, security tools, incident response. Hands-on labs included.	https://skillsbuild.org
Fortinet NSE Certification Path (Levels 1–3)	Free	Vendor-neutral cybersecurity fundamentals. Topics: threat landscape, attacks, securing networks, FortiGate basics.	https://www.fortinet.com/nse-training

2. Foundations of System & Network Knowledge

2.1 Linux – The Basics You Should Know

Linux is an **open-source operating system** used everywhere in cybersecurity, servers, and cloud systems.

What you must know:

- How to navigate the terminal (cd, ls, pwd)
- File management (cp, mv, rm, touch, mkdir)
- File system hierarchy (/home, /var, /etc)

Understanding **/etc/passwd** (list of system users)

- User and permission management (chmod, chown, sudo)
- Package management (apt, yum, pacman)
- Basic networking commands (ping, netstat, ifconfig/ip, ssh)
- Understanding system logs and where to find them

2.2 Linux System Administration (Gestion d'un système Linux)

This means **managing and maintaining a Linux system**, not just using it.

Key basics:

- Creating and managing users, groups, and permissions
- Managing system services (Apache, Nginx, MySQL)
- Disk management (mount, partitions, LVM)
- Process management (ps, top, kill)
- Scheduling tasks (cron jobs)
- Backup and restore strategies
- Securing the system (firewall rules, SSH hardening)
- Updating the system and installing software

This is essential for server administration and cybersecurity.

Badly configured services can expose a server to attacks.

2.3 Windows System Administration (Management) (Active Directory)

Windows System Administration focuses more on **GUI tools**, but also **PowerShell** and **network management**.

Active Directory (AD) is the **identity and access management** system for Windows environments (companies, organizations, schools).

What you must know:

- How a domain, users, and computers are organized
- Managing users, groups, passwords, and access rights

- Group Policy (GPO) to control security settings and configurations
- Domain controllers and how authentication works
- File sharing and permissions
- Understanding LDAP, Kerberos, and AD hierarchy (OU, Forest, Domain, Trees)
- Basic PowerShell commands for automation

AD is very important for cybersecurity because many attacks target Windows domains (privilege escalation, lateral movement).

3. Networking Essentials for Web Security

3.1 OSI Model (Open Systems Interconnection)

The OSI model is a **7-layer framework** that explains how data moves from one device to another over a network.

Each layer has a specific role and works with the layers above and below it.

3.1.1 Simplified Overview:

The OSI Model explains how data moves across a network:

Layer	Name	Relevance to Security
3	Network	IP routing, attacks targeting IP addresses
4	Transport	TCP & UDP exploitation
7	Application	Web attacks (XSS, SQLi, LFI, etc.)

3.1.2 More Detailed Overview:

1. Physical Layer (Layer 1)

- Moves raw bits (0s and 1s) through cables, fiber, Wi-Fi signals
Examples: Ethernet cables, switches, Wi-Fi, electrical signals

2. Data Link Layer (Layer 2)

- Handles communication between devices on the same local network
- Uses MAC addresses
- Detects/Corrects basic errors
Examples: MAC address, ARP, switches, VLANs

3. Network Layer (Layer 3)

- Handles routing of data between networks
- Uses IP addresses
Examples: IP, ICMP (ping), routers, IPv4/IPv6

4. Transport Layer (Layer 4)

- Ensures data gets to the right application
- Splits and reassembles data
- Provides reliable or unreliable transport
Examples: TCP (reliable), UDP (faster but no guarantee), ports (80, 443, 22...)

5. Session Layer (Layer 5)

- Manages connections/sessions between devices
Examples: Opening, maintaining, closing sessions (e.g., login sessions)

6. Presentation Layer (Layer 6)

- Formats and encrypts data
Examples: SSL/TLS encryption / Data encoding (JSON, XML)

7. Application Layer (Layer 7)

- Interface where users interact with the network
Examples: HTTP, HTTPS, DNS, FTP, SMTP / Web browsers, email apps

3.2 TCP vs UDP

3.2.1 TCP (Transmission Control Protocol)

Reliable – Connection-based

- Creates a connection between two devices before sending data (**3-way handshake**)
- Guarantees that all data arrives **in order and without loss** (eg: send message letter by letter)
- Retransmits lost packets
- Slower but **very reliable**

Used for: Web browsing (HTTP/HTTPS) / Emails (SMTP, IMAP, POP3) / File transfer (FTP)

Anything that needs accuracy, not speed

3.2.2 UDP (User Datagram Protocol)

Fast – Connectionless

- Sends data **without establishing a connection** (send all the msg together)
- No guarantee data arrives
- No checking, no correcting → **very fast**
- Used when **speed matters more than reliability**

Used for: Video streaming / Online gaming / VoIP calls / DNS queries

3.3 Routers vs Switches

Switch = connects devices inside the same network (use MAC)

MAC = physical address, used inside the local network by switches

Router = connects different networks together (use IP)

IP = logical address, used for routing between networks

3.3.1 Switch (Layer 2 Device)

A **switch connects** multiple devices **inside the same local network (LAN)** and lets them communicate efficiently. Use to **Creates and manages the local network**.

- Works with **MAC addresses (Hardware Address Only (No ID))**

A **MAC address** is a **physical identifier** burned into the network card.

- Used by **switches**
- Identifies a device **inside the same local network**
- Never leaves the LAN (local only)
- Does **not** give “identity” in the internet sense → just a hardware tag

Example: **A4:5E:60:AF:22:9B**

Roles: It Forwards data only to the correct device (unicast), Reduces network collisions & Used inside offices, homes, and companies

About **MAC Spoofing**

Attackers can fake a MAC address to:

- Bypass restrictions
- Monitor traffic
- Impersonate devices

3.3.2 Router (Layer 3 Device)

A router **connects different networks** together, like your home network to the internet. Used to **connect your local network to other networks (including the internet)**.

- Works with **IP addresses (IP Address: “Direction + ID)**

IP address identifies a device **on a network** & tells routers **where to send the data**.

- Acts like a home address → direction + identity

- Used by **routers** to move data between networks
- Changes depending on the network (Wi-Fi, 4G, etc.)

Example: 192.168.1.10

Roles: It Decides the best path to send data between networks, Provides NAT, DHCP, firewall features & Essential for internet access

4. Networking Concepts Relevant to Attacks

4.1 FIFO & LIFO

4.1.1 FIFO = widely used

FIFO (First In, First Out): common in network queues; packets processed in arrival order.

Example: Packets arrive: **A, B, C** → They leave in the same order **A, B, C**

4.1.2 LIFO = almost never used

LIFO (Last In, First Out): used in other computing processes but less in networking.

Example: Packets arrive: **A, B, C** → They leave: **C, B, A**

4.2 Proxy Servers

A proxy acts as a **middleman** between the user and the internet. (Your device → **Proxy** → Website)

Functions:

- **Hides the real IP address**
- Filters requests
- Can allow anonymous browsing
- Provides caching for faster access

A proxy server is *not automatically* a cloud server.

But a **proxy can be hosted on a cloud server**, and this is very common. (A **cloud server** is just a server **hosted on the internet** instead of a physical machine at home.)

4.3 Tor Browser & Onion Routing

Tor Browser allows users to **browse the internet anonymously**, including accessing parts of the **Deep Web** and **Dark Web**.

It protects privacy by wrapping your traffic in **multiple layers of encryption** (like the **layers of an onion**) and sending it through **three randomly selected Tor nodes**:

- **Entry Node** – sees your IP but not what you access
- **Middle Relay** – only forwards encrypted traffic
- **Exit Node** – sees the destination but not who you are

These encryption layers ensure that **no single node knows both your identity and your activity**. This makes Tor a powerful tool for privacy, research, and bypassing censorship—though it can also be misused for illegal purposes.

5. DNS Concepts and Attacks

5.1 DNS (Domain Name System)

DNS translates human-friendly names (e.g., google.com) into IP addresses.

It is the **internet's phone book**.

5.2 DNS Cache

A temporary memory storing recent DNS resolutions to speed up browsing.

Your device **save previous DNS lookups for Faster website loading & Less network traffic**

5.3 Local DNS Server

Usually hosted by your ISP (**Internet Service Provider's**); **resolves queries for users in the network**.

first point of contact for domain resolution

5.4 DNS Poisoning (DNS Spoofing)

An **attack** where the DNS records are manipulated (**inserts fake DNS entries**) to **redirect users** to:

- Fake login pages
 - Example: Instead of real Facebook → attacker's fake login page
- Malicious websites
- Phishing pages

How it works (simple):

An attacker tricks a DNS server into storing:

google.com → **5.5.5.5** (attacker-controlled IP)

All users relying on that DNS server will be redirected to the fake site.

6. Tools Used in Web Exploitation

6.1 Wireshark microscope for network traffic

See everything happening on your network

- Network packet capture tool
- Analyzes traffic at all OSI layers
- Used for debugging and network forensics

6.2 Burp Suite toolkit for hacking websites

Attack and analyze websites

- Professional web exploitation toolkit
- Intercepts HTTP requests
- Modifies and replays requests
- Used for OWASP vulnerabilities (SQLi, XSS, CSRF, etc.)

6.3 Wireshark vs Burp Suite

Feature	Wireshark	Burp Suite
Purpose	Network traffic analysis	Web pentesting
Layer	Network stack (TCP/UDP, DNS...)	Application (HTTP/HTTPS)
Use case	Monitoring packets	Testing website vulnerabilities
Shows	Raw packets	Web requests & responses
Used by	Network engineers + pentesters	Web pentesters
Best for	Detecting network attacks	Exploiting web apps

7. OWASP Top Ten

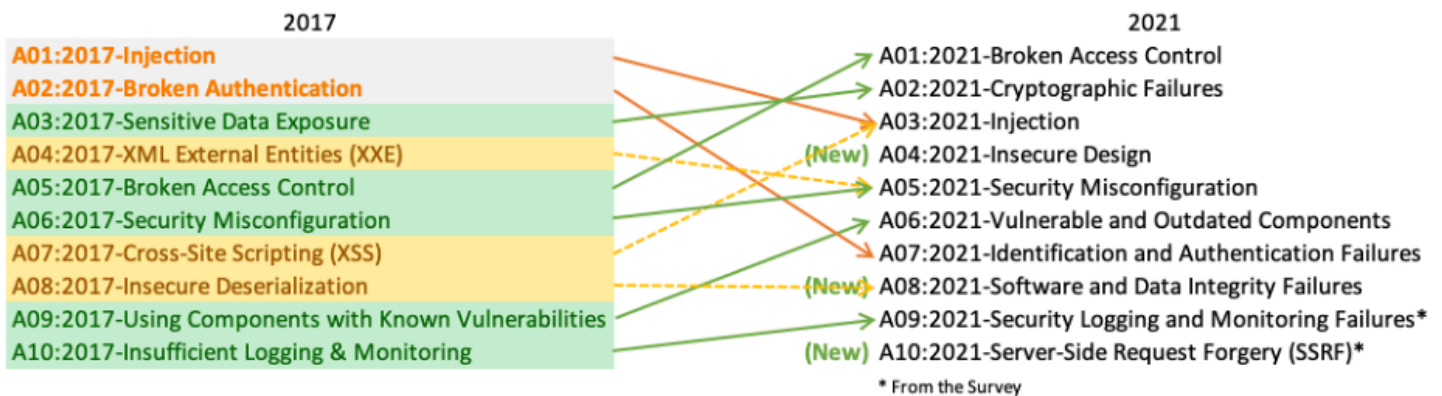
The OWASP Top Ten represents the **10 most critical web application vulnerabilities**:

1. Broken Access Control
2. Cryptographic Failures
3. Injection (SQLi, XSS, Command Injection)
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable Components

7. Identification & Authentication Failures
8. Software Integrity Failures
9. Logging & Monitoring Failures
10. SSRF (Server-Side Request Forgery)

These serve as the main learning framework for web security.

The **updates** of those 10 **web application vulnerabilities** through the years:



8. Hands-On Practice Platforms: DVWA & Mutillidae

Both are **intentionally vulnerable web applications** created for **learning and practicing web exploitation**

8.1 DVWA (Damn Vulnerable Web Application)

A platform deliberately made insecure for training on:

SQL Injection / XSS / CSRF / File Inclusion / Brute-force attacks

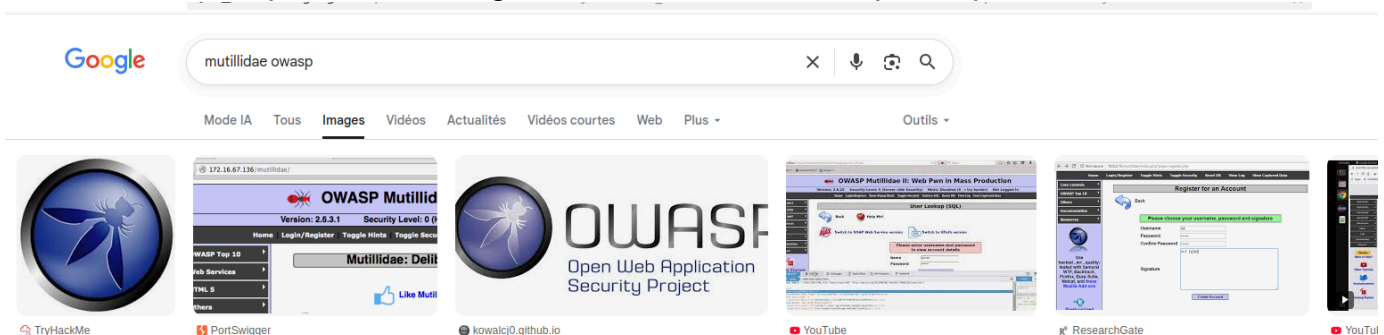
Security levels (Low, Medium, High, Impossible) allow students to see:

How attacks work / How protections block them

8.2 Mutillidae OWASP

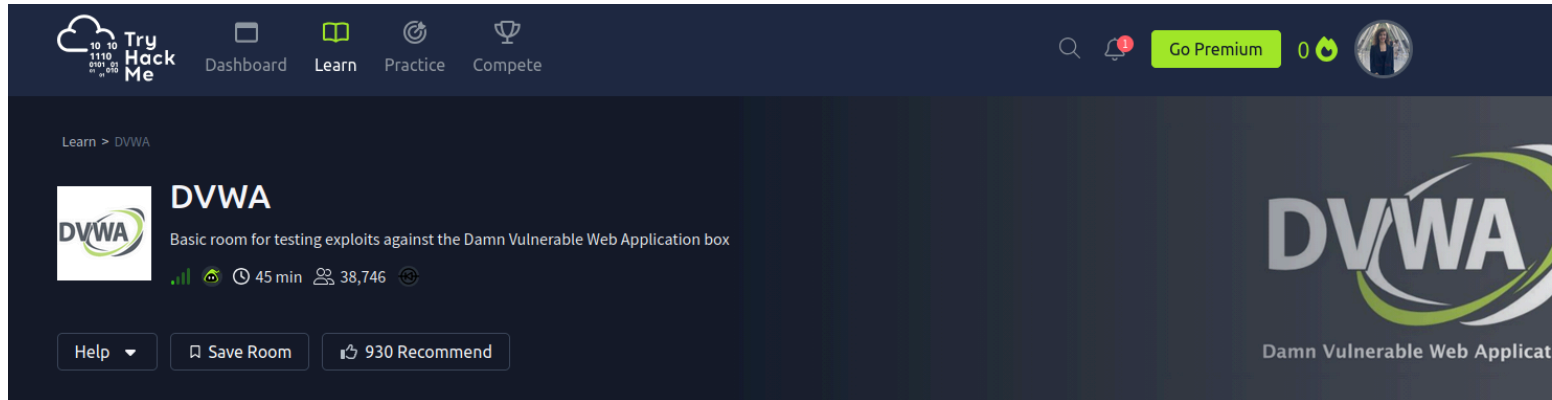
Another intentionally vulnerable application focusing on:

OWASP Top Ten / Misconfigurations / Insecure development practices



II. Practical Demonstration:

1. Open TryHackMe: [link: https://tryhackme.com/hackactivities](https://tryhackme.com/hackactivities)
2. Create account
3. Search for DVWA



4. Manage Account by **changing the region**

To access material, start machines and answer questions you need to join this room!

Join Room

! The following task machines are not available in your current VM region:

- Task 1 - Accessible from: US East (N. Virginia), Asia Pacific (Mumbai)

Head to the [Manage Account](#) page to switch your VM region.

Alternatively, you could ask the owner of the machine to migrate it to another region.

Task 1 ○ DVWA

DVWA is an awesome virtual machine commonly utilized in training and testing of new tools. This room is unguided and acts purely as a testing environment.

▶ Start Machine

The credentials to login can easily be found online, but they are also included in the hint below, should you prefer to take the easy route.

Answer the questions below

Deploy the VM and start hacking!

Join this room

Join this room

🔍 Hint

⚙️ Manage account

Account Details

Preferences

Subscription

CTF Teams

Develop rooms

VM and VPN Settings

🌐 VM Region

To access machines, select the region closest to you for the best performance.

US East (N. Virginia)

5. click on: **access machine**

The image shows the DVWA (Damn Vulnerable Web Application) interface. At the top, there's a header with the DVWA logo and the text "Basic room for testing exploits". Below this, there's a status bar showing "45 min" and "38,755". A notification box at the top right says "Starting your machine... please wait!". Another notification box below it says "Hooray! Your machine has started. It may need a few minutes to become accessible." Below the notifications, there are buttons for "Start AttackBox", "Save Room", and "930 Recommend". A "Room progress (0%)" bar is visible. The main content area is titled "Target Machine Information" and contains a table with the following data:

Title	Target IP Address	Expires
DVWA	Shown in 0min 57s	59min 57s

Below the table, there are buttons for "?", "Add 1 hour", and "Terminate".

6. Click on Start AttackBox

7. Click on attackBox

The image shows a screen with the title "You are disconnected". Below the title, it says "To access target machines you need to either:". There are two options listed:

- AttackBox**: Use a browser-based attack machine
- OpenVPN (Advanced)**: Connect to our network via a VPN

The image shows a screen with the title "Your machine is initializing...". Below the title, it says "Use the AttackBox to attack machines you start on tasks". There is a progress bar showing "Loading (4%)". A notification box at the top right says "Hooray! Your machine has started. It may need a few minutes to become accessible." The bottom of the screen shows a taskbar with the text "THM AttackBox".

8. Machine opens

The screenshot shows the TryHackMe DVWA room interface on the left and a terminal window on the right. The room interface includes a header with the DVWA logo and a description: "Basic room for testing exploits against the Damn Vulnerable Web Application box". It shows a progress bar at 0% and a "Target Machine Information" table.

Title	Target IP Address	Expires
DVWA	10.201.102.248	54min 38s

Below the table are buttons for "?", "Add 1 hour", and "Terminate". The "Task 1" section describes DVWA as a virtual machine for training and testing, with a "Start Machine" button.

The terminal window on the right shows the root's Home directory and a terminal output with the following text:

```
2. You are solely responsible for your actions.
3. This machine expires. Check TryHackMe to ensure you still have time left.
4. Once this machine is terminated, all data will be lost.
5. If you are a subscriber, this machine is exposed to the internet and maybe automatically scanned. While the machine is secure, do not store sensitive files.

Usage Instructions:
1. Tools are located in /root/Desktop/Tools & /opt/
2. Webshells are located in /usr/share/webshells
3. Wordlists are located in /usr/share/wordlists
4. READMEs are located in /root/Instructions
5. To use Empire & Starkiller, read the following file: /root/Instructions/empire-starkiller.txt

Do you think something's missing? Let us know! support@tryhackme.com

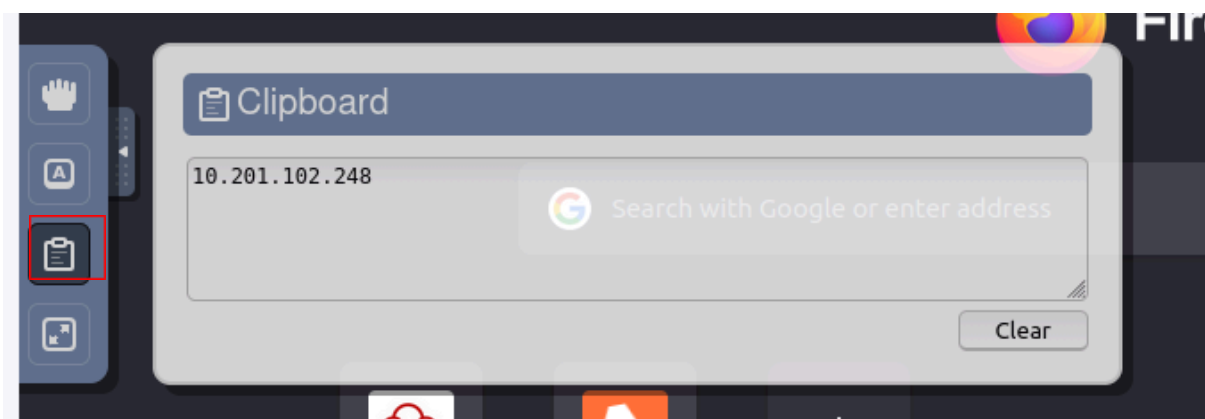
Press ENTER key to close.
```

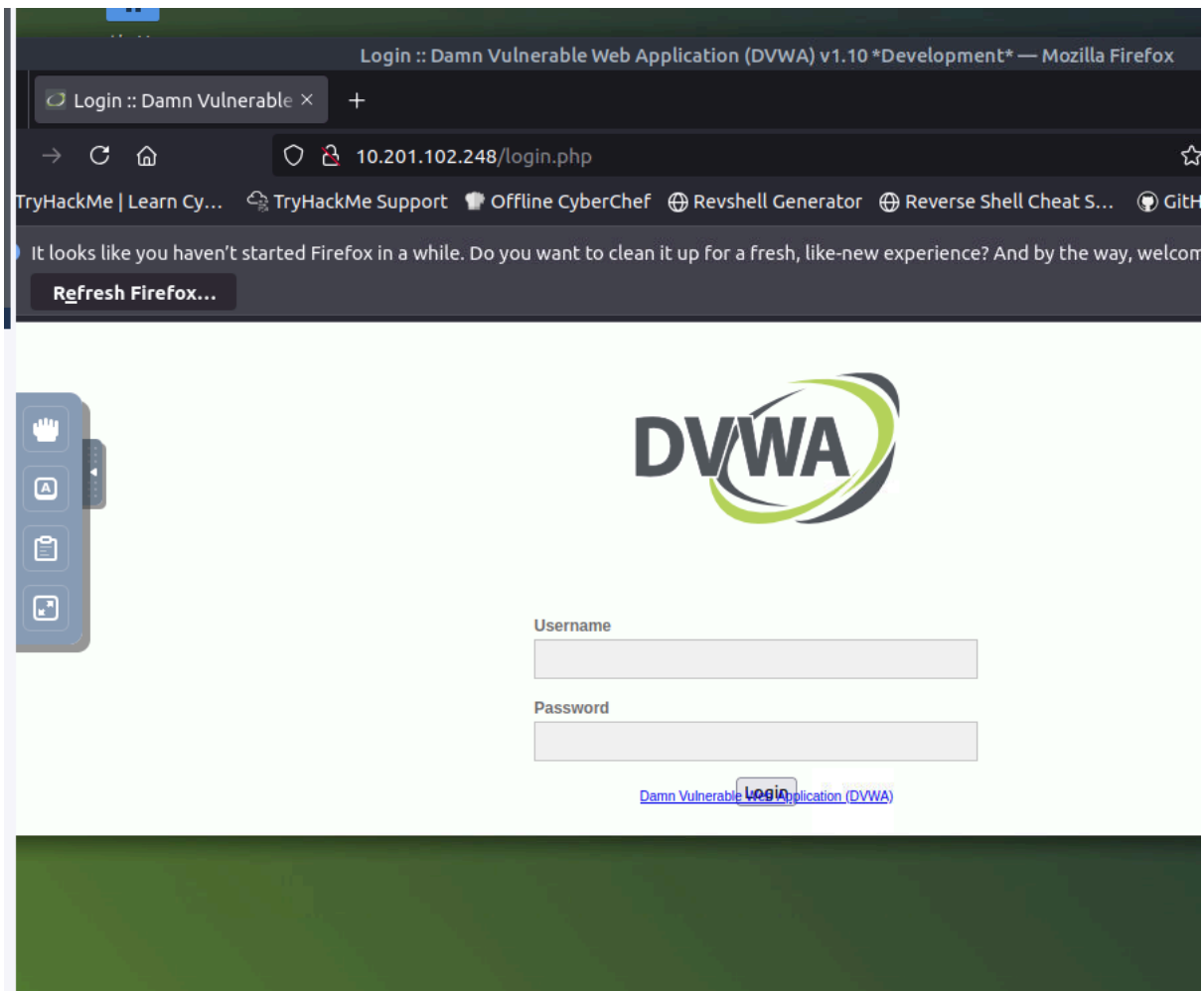
9. Copy Target IP Address: 10.201.102.248

10. Paste it the URL of firebox

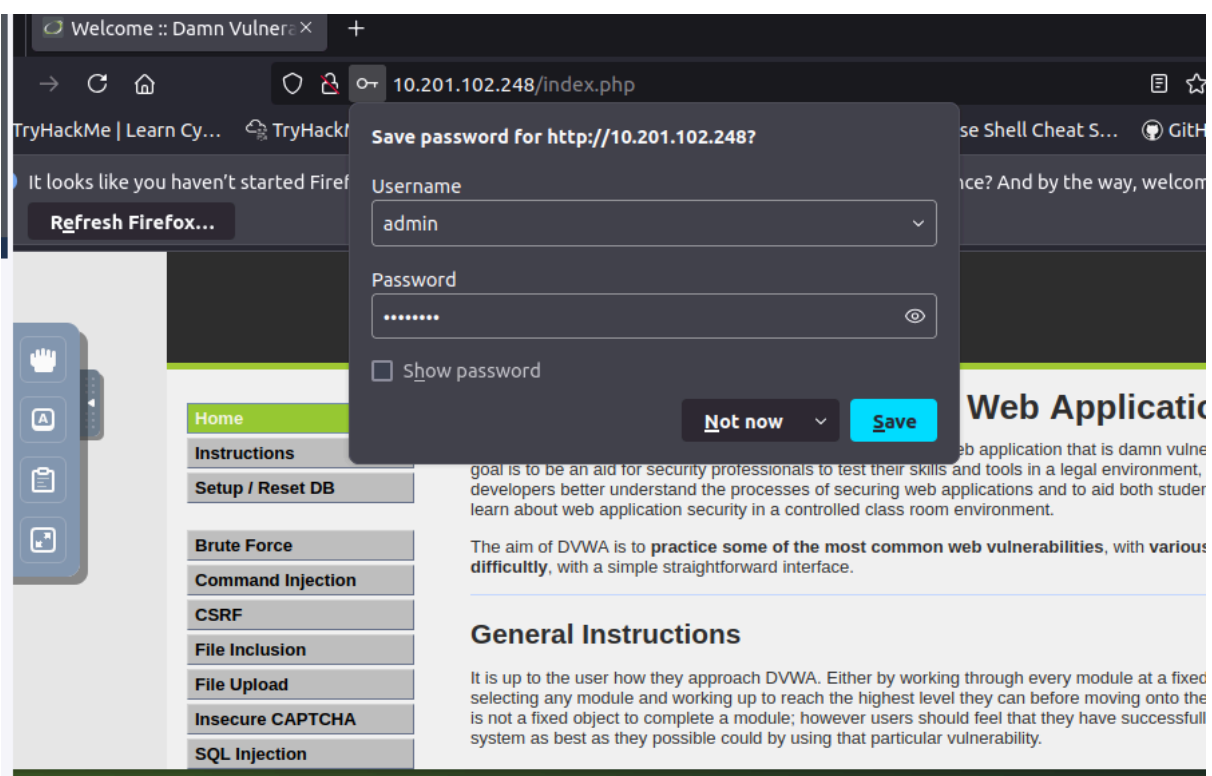
11. If PAST did not work

Click on clipboard





12. Username: admin
Password: password



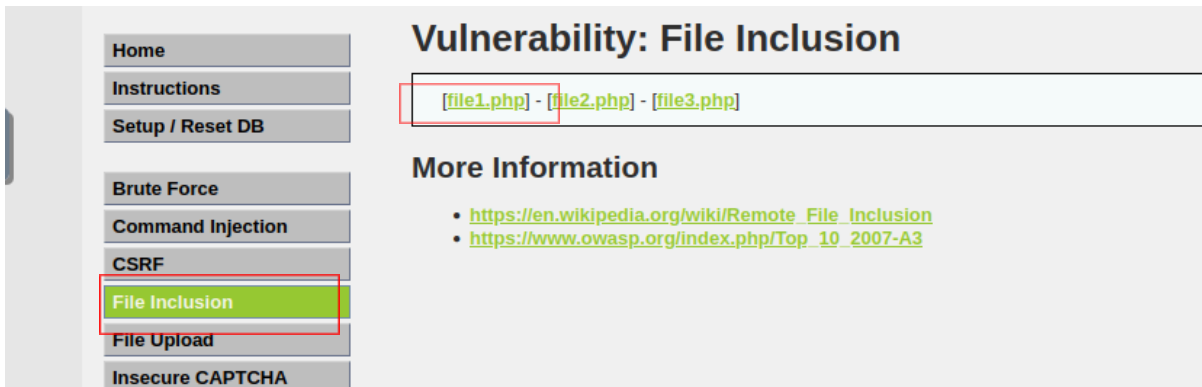
13. Click on DVWA Security

The screenshot shows the DVWA Security page. On the left is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, DVWA Security (highlighted with a red box), and PHP Info. The main content area is titled 'DVWA Security' with a lock icon. Below the title is the 'Security Level' section, which states 'Security level is currently: impossible.' and explains that the level can be set to low, medium, high, or impossible. A list of four levels is provided: 1. Low (completely vulnerable), 2. Medium (bad security practices), 3. High (extension to medium difficulty), and 4. Impossible (secure against all vulnerabilities). At the bottom of this section is a dropdown menu currently set to 'Impossible' and a 'Submit' button. Below this is the 'PHPIDS' section, which describes the PHP-Intrusion Detection System as a security layer for PHP-based applications.

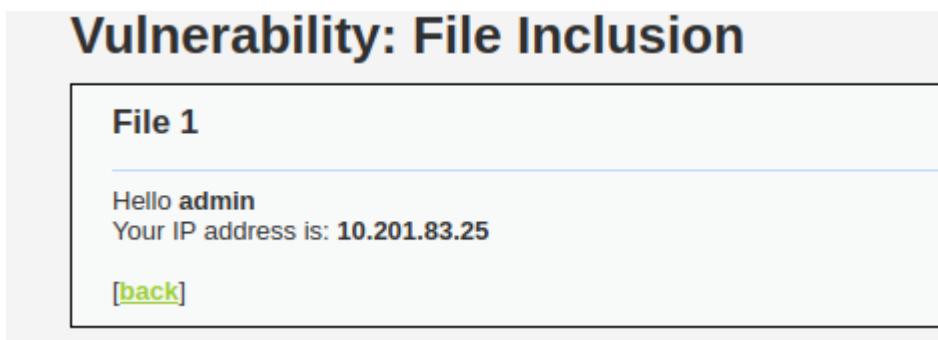
14. Change security level to low

This screenshot shows the same DVWA Security page as the previous one, but with the 'Security Level' dropdown menu open. The dropdown menu is located at the bottom of the 'Security Level' section and shows four options: 'Low' (highlighted with a red box), 'Medium', 'High', and 'Impossible'. The 'Submit' button is still visible next to the dropdown. The rest of the page content, including the sidebar and the PHPIDS section, remains the same.

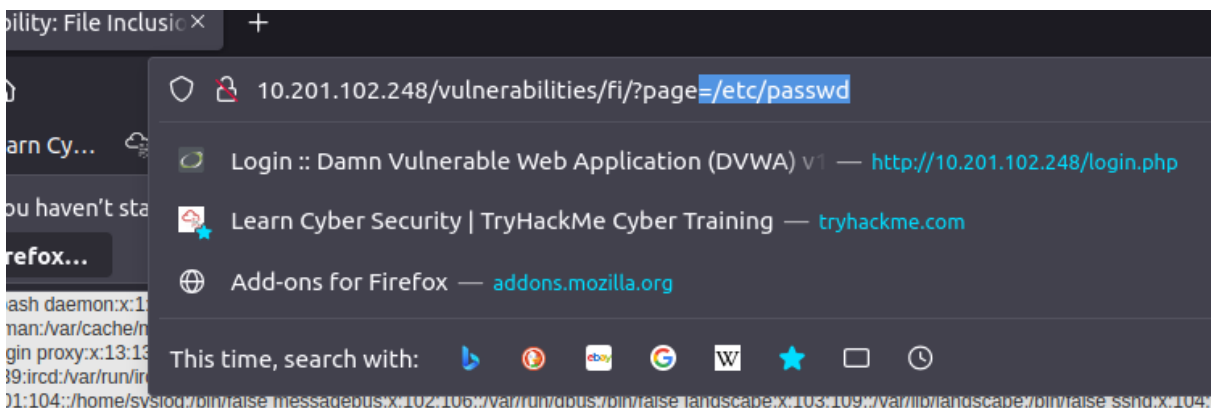
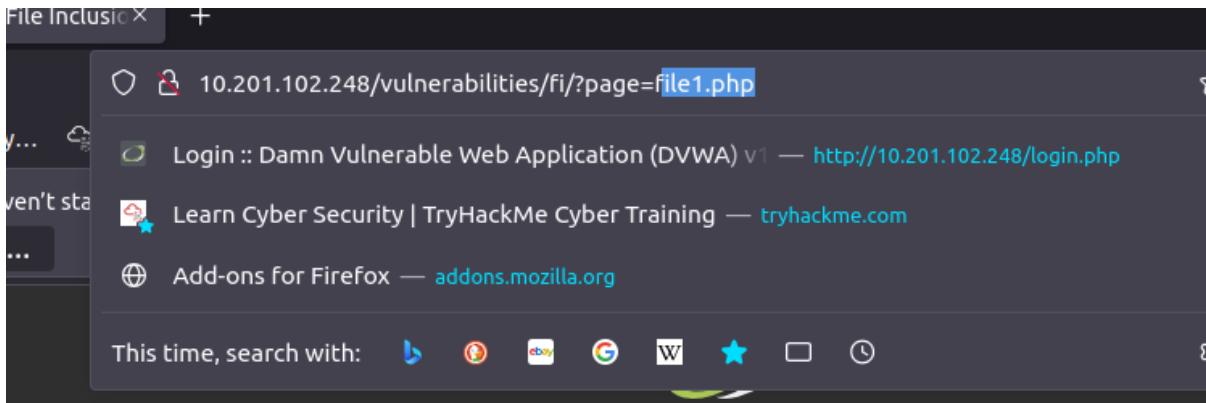
15. Click on File Inclusion

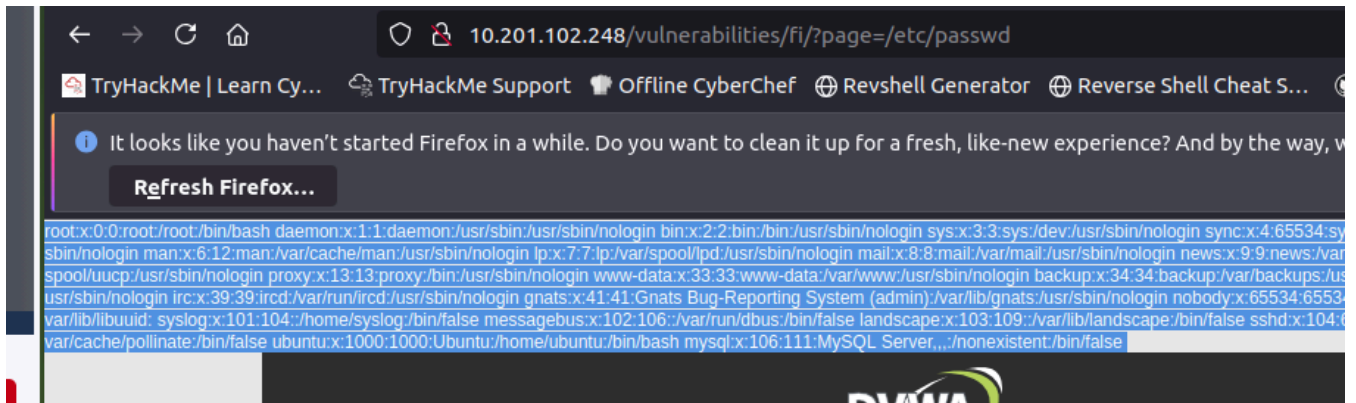


16. Check file



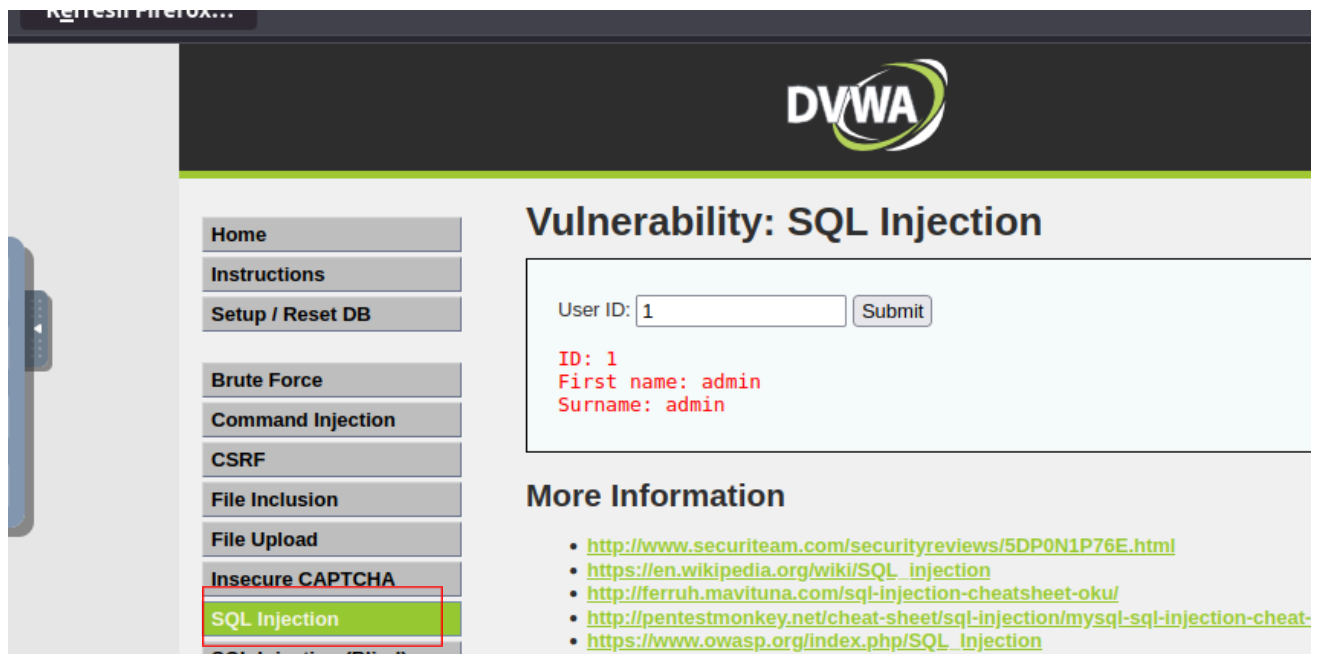
17. In order to **check all the users**, change **file1.php** → **/etc/passwd**



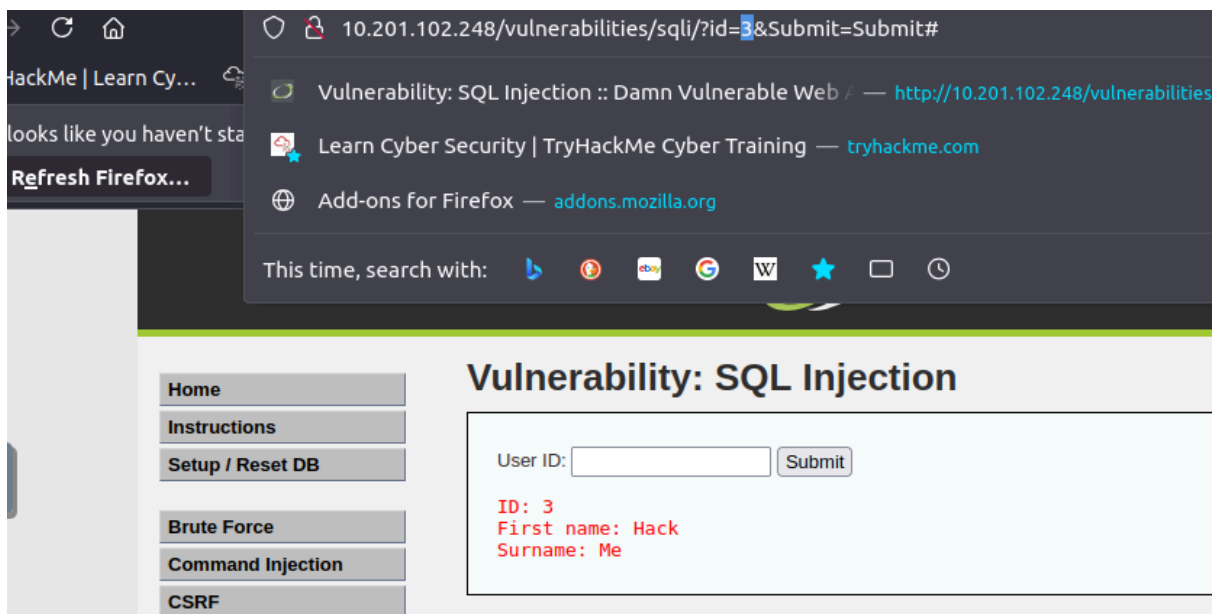


18. Click on SQL Injection

You can choose to see ID by typing in the **input field**

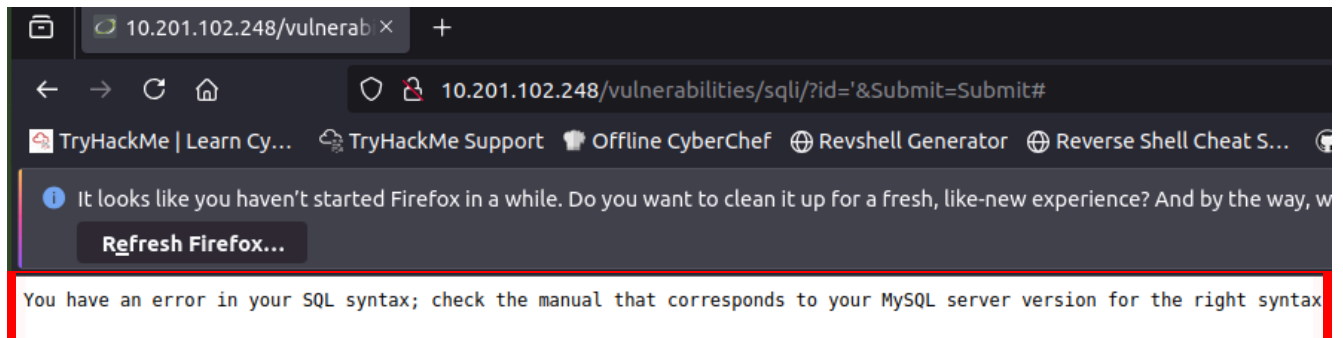


OR through changing the number in the URL



19. What happens when we give an input of ' ?

User ID: Submit



That shows that there is an **interpretation** occurred in the database

20. Show all the database by typing: ' or 1=1 #

Vulnerability: SQL Injection

User ID: Submit

Vulnerability: SQL Injection

User ID: Submit

ID: ' or 1=1 #
First name: admin
Surname: admin

ID: ' or 1=1 #
First name: Gordon
Surname: Brown

ID: ' or 1=1 #
First name: Hack
Surname: Me

ID: ' or 1=1 #
First name: Pablo
Surname: Picasso

ID: ' or 1=1 #
First name: Bob
Surname: Smith

EXPLANATION:



Breakdown:

✓ `' '`

Closes the original string.

✓ `OR 1=1`

`1=1` is **always TRUE**, so the condition becomes **TRUE for all rows**.

✓ `--`

SQL comment operator (in MySQL, Oracle, PostgreSQL).

Everything after `--` is ignored by the database.

So the database executes only:

sql

Copy code

```
SELECT * FROM users WHERE TRUE;
```

This returns **all the rows in the table**.



Normal Query (before injection)

A website might have a query like:

sql

Copy code

```
SELECT * FROM users WHERE id = 'USER_INPUT';
```

If the attacker enters:

vbnet

Copy code

,

It breaks the query:

sql

Copy code

```
SELECT * FROM users WHERE id = '';
```



Injecting: `' or 1=1 --`

Attackers add:

vbnet

Copy code

```
' OR 1=1 --
```

So the full query becomes:

sql

Copy code

```
SELECT * FROM users WHERE id = '' OR 1=1 --';
```

SQL Injection Security Levels (DVWA)

Medium: Basic filtering / Still vulnerable

High: Strong filtering / Blind/time-based attacks needed

Impossible: Uses prepared statements / No SQL injection possible

21. Click XSS (reflection)

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass

Vulnerability: Reflected Cross Site Scripting

What's your name?

Input field

More Information

- [https://www.owasp.org/index.php/Cross-site_Scripting_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <http://www.cgisecurity.com/xss-faq.html>
- <http://www.scriptalert1.com/>

In the input field we should do injection

user/ user ID: sql injection /xss injection

The easiest way to show an alert in JavaScript

22. Search for script

Google search results for 'xss cheat sheet document'.

Mode IA Tous Images Vidéos Vidéos courtes Actualités Web Plus Outils

PortSwigger
https://portswigger.net > cheat-sheet · Traduire cette page

Cross-Site Scripting (XSS) Cheat Sheet - 2025 Edition

Interactive cross-site scripting (XSS) cheat sheet for 2025, brought to you by PortSwigger. Actively maintained, and regularly updated with new vectors.

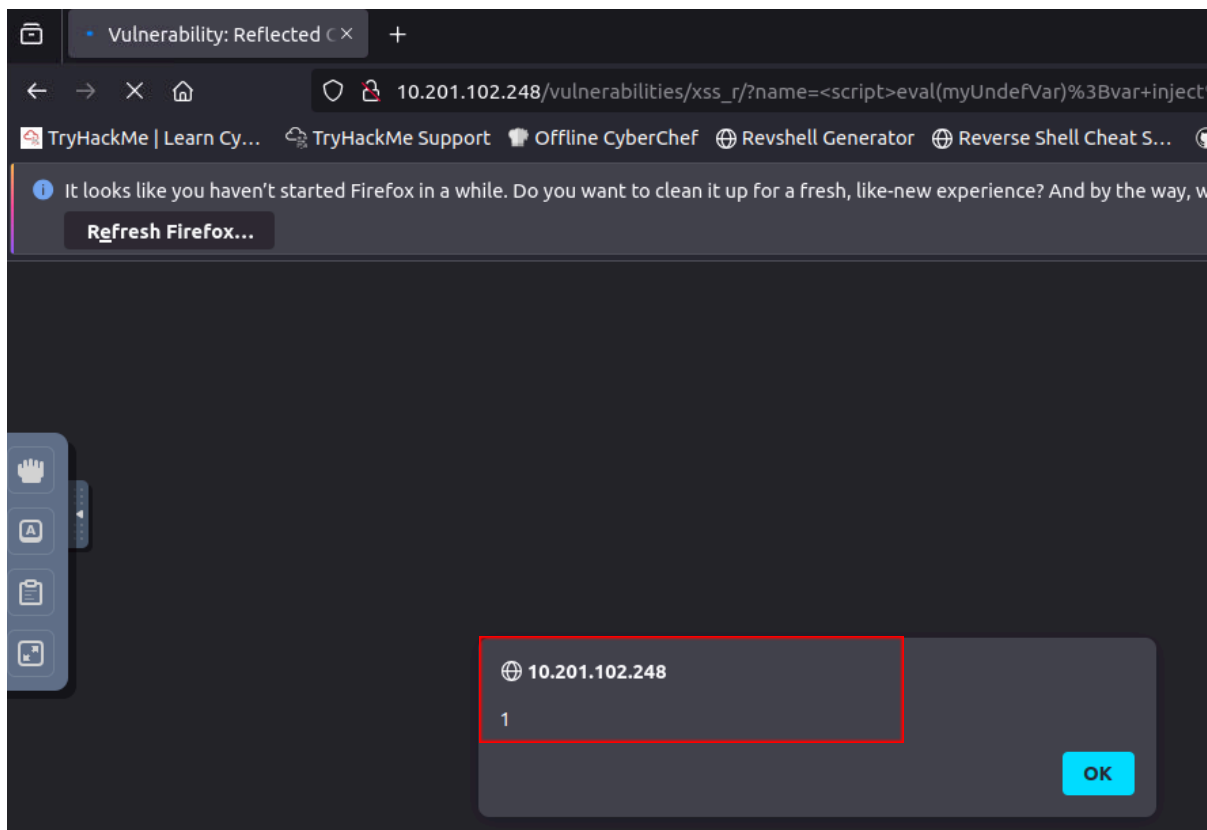
OWASP
https://cheatsheetseries.owasp.org > ... · Traduire cette page

Cross Site Scripting Prevention Cheat Sheet

23. Past the code in the input field

Eg: `<script>eval(myUndefVar);var inject="INJECTION_STARTS_HERE";var myUndefVar;alert(1);/";</script>`

24. output:



Explore More:

PortSwigger Web Security Academy (free online platform offering detailed labs)

PicoCTF (beginner friendly)

HackTheBox (advanced)

RootMe (experts)

Trainer: SABER BOUKHRISS

Done by: SAHAR FEKI

Training Manager & External Relation Manager